

USD8

USD8

Security Audit Report

Contents

Disclaimer	3
Introduction	3
State overview	3
Scope	3
Assumptions	3
Findings	4
Medium	4
Medium 01 - Admin Claimant Can Steal Other Claimants' Insured Tokens	4
Low	4
Low 01 - Funded Rewards Become Unclaimable After Share Inflation	4
Low 02 - Pool Exits Fail After Share Supply Reaches Its Limit	5
Low 03 - Treasury Reserve Can Be Impaired By Vault Share Rounding	5
Low 04 - Incident Claims Can Lose Their Payout Route	6

Disclaimer

This review assesses the security of the specified code and commit based on the information available during the review. It cannot guarantee that every vulnerability has been identified or that the system is free from security risks. Changes made after the reviewed commit are outside this assessment and may introduce new vulnerabilities. This report does not replace ongoing security practices, testing, or independent review.

Introduction

USD8 is a USDC-backed stablecoin with integrated DeFi insurance. The Treasury manages USDC reserves and approved strategies, while cover pools provide insurance capital and distribute rewards. Users can escrow insured tokens to join an incident claim; authorized TEE signers approve incident openings and settlement roots, which determine claim payouts.

For more information, visit the USD8 protocol website.

State overview

A total of 5 issues have been raised:

- **Medium:** 0 of 1 fixed; 1 open.
- **Low:** 0 of 4 fixed; 4 open.

Scope

- **Repository:** https://github.com/Usd8-fi/usd8-core
- **Commit:** `6efab51299d551ed45b20d82b305d300e9f01d7b`
- **Files:**
- `src/DefiInsurance.sol`
- `src/Registry.sol`
- `src/SharedBase.sol`
- `src/SingleAssetCoverPool.sol`
- `src/Treasury.sol`
- `src/USD8.sol`

Assumptions

Privileged roles are assumed to act with good intention.

- **Timelock:** Controls protocol configuration, upgrades, strategy approval, insured-token settings, and the authorized TEE signer set.
- **Admins:** Handle immediate operational actions such as pausing, reserve operations, and profit routing; during beta they can also open incidents and correct settlement roots.
- **TEE signers:** Authorize incident openings and sign settlement roots used to determine claim payouts.

Files outside the listed scope and the **USD8 Rust settlement runtime**, which generates settlement proofs, are trusted.

Findings

Medium

01. Admin Claimant Can Steal Other Claimants' Insured Tokens

An admin claimant can exploit the claimant cancellation to divert funds reserved for other claims before its own refund completes.

1. Alice and Mallory each escrow 100 units of the same insured token. Mallory is a contract claimant with admin authority and one booster. When Mallory calls `cancelClaim`, it reduces protected escrow before sending her refund. The booster return invokes Mallory's receiver before the insured-token transfer (booster return).

2. During that callback, Mallory calls `sweepToken`, which lets an authorized admin transfer apparent surplus. The surplus calculation uses the already-reduced insured-token liability (`_sweepable`). The cancellation reentrancy guard does not cover this sweep entry point. This also permits sweeping a pending insured-token refund when USD8 is the insured token, because the bond reserve does not include that refund.

3. The sweep transfers Alice's 100 tokens to Mallory. Cancellation then sends Mallory her separate 100-token refund (refund transfer). Alice's claim remains recorded, but her later refund reverts because the tokens are gone. Proofless recovery uses the same liability-before-transfer ordering (`_resolveWithoutSettlement`).

Consider keeping each pending insured-token refund in protected escrow until its transfer completes in both cancellation and proofless recovery.

Low

01. Funded Rewards Become Unclaimable After Share Inflation

Repeated insurance payouts reduce accounted assets without burning shares, and later deposits use ERC-4626 share conversion based on total assets and supply. The payout-cap setter allows any nonzero value below the 10,000-bps denominator, permitting near-total payouts. Repeated losses and replenishments can therefore inflate share supply until the fixed reward scale no longer represents hourly emissions accurately.

1. After sufficient share inflation, a seven-day reward stream of 70 USD8 can be checkpointed hourly by a shareless account making zero-value self-transfers. The pool checkpoints rewards on transfers and floors each interval's emission before advancing the checkpoint time.

2. In the demonstrated state, 168 hourly checkpoints leave users with no earned rewards. Later notifications schedule only new funding and remaining scheduled emissions, so the stranded amount cannot be claimed or returned to a future stream. Principal remains unaffected.

Consider using reward accounting that carries fractional remainders across checkpoints and preserves reward entitlement across the full reachable share-supply range.

02. Pool Exits Fail After Share Supply Reaches Its Limit

Insurance payouts reduce pool assets without burning shares, and later deposits mint against the reduced backing. After repeated losses and replenishments, share supply can approach the limit used by inherited ERC-4626 conversions. The payout-cap setter permits near-total payouts, and the pool's claim-payment path reduces accounted assets without reducing supply.

1. After repeated loss and replenishment cycles, an unprivileged minter can push the pool's share supply into an unsafe range. The pool's mint limit does not reserve conversion headroom, while its ERC-4626 conversion adds virtual shares to total supply. Near the integer limit, that addition overflows during later conversions.

2. A minter can retain one share while other holders queue the rest for withdrawal. Because the queued shares do not equal total supply, exit settlement uses the partial-supply conversion, which reverts on overflow. The pool also settles matured exits before opening an insurance incident, so the stuck pool can block unrelated incident openings. A full-supply exit avoids this conversion path, but requires the holder of the retained share to cooperate.

Consider limiting resulting supply to `type(uint256).max - 10 ** _decimalsOffset()` in the common deposit and mint path, and cap `maxMint` at the remaining safe headroom.

03. Treasury Reserve Can Be Impaired By Vault Share Rounding

The shipped ERC-4626 adapter accepts a deposit whenever the value credited by the vault is within one post-deposit share of the amount sent. If a standard vault's share price has been raised by a donation, that tolerance can allow a material shortfall, reducing the USDC backing for outstanding USD8.

1. Mallory seeds a public ERC-4626 vault with one USDC base unit (0.000001 USDC) and donates 500 USDC, raising the vault share price through its virtual-share conversion. Governance approves the vault through the strategy admission path.

2. Trent allocates 500 USDC through Treasury's strategy deposit path. The adapter receives one vault share and values it at ~333.33 USDC. Its one-share-plus-one-unit tolerance accepts the deposit, and Treasury does not bound the resulting reserve reduction.

3. Treasury's reserve valuation includes the adapter's reported share value. USD8 remains backed by only ~333.33 USDC, so a full redemption pays from that impaired reserve. The demonstrated donor spends about ~166.66 USDC to cause about ~166.66 USDC of reserve loss, leaving them with no clear profit.

Consider measuring Treasury's aggregate USDC reserve before and after each strategy deployment and reverting if a successful deployment reduces it by more than a fixed USDC-denominated rounding allowance.

04. Incident Claims Can Lose Their Payout Route

A timelock operation queued to clear the insurance module for an earlier incident can remain executable after that incident ends. The shipped timelock uses a 24-hour delay and allows anyone to execute ready operations. `Registry.setDefiInsurance` allows the timelock to clear the module even while an incident is active, and the queued operation is not tied to the incident for which it was scheduled.

If that ready clear is executed during a later incident, the insurance module can no longer submit its settlement root, and the cover pool rejects its payouts because it is no longer registered. A claimant can recover the escrow and bond without settlement, but loses the opportunity for an insurance payout from that incident. Settlement requires the module to remain registered, removed-module claims can only use the recovery path, and the cover pool pays only the registered module.

Consider binding a module-clear operation to the expected module and incident generation, then rejecting execution if either has changed. Preserve a separate emergency path for a stuck module or one whose activity check fails.